

Lecture 46

Cyber Security and Privacy - Capstone Discussion B

Cyber Security and Privacy | NPTEL 106106248

Prof. Saji K. Mathew, IIT Madras

Video: <https://www.youtube.com/watch?v=nlsz8MggiAU>

Study transcript from publicly available YouTube captions. Course content and video rights belong to NPTEL / IIT Madras. For personal study only.

audible yes you are yeah thank you Professor I'll share my screen so once again good afternoon everyone and welcome to the course cyber security and privacy live interaction so today as part of the course I'll be taking the topic Insider threats and information security I am Bala gopal and the TA for this course so if you look at this slide you can see recent news articles which contains the word Insider for example ver Ison Insider data breach impacted data of more than 60,000 employees malatia Insider threats are increasing in UAE trust waves 2024 Financial Service reports that Insider threat is an alarming Trend so in all these news article you can see the term Insider and when people think about cyber security attacks or cyber security incidents the the the people that might come to their mind is the hackers or the external hackers or the Cyber criminals so this Cyber attack can come from internal as well that means this cyber attacks or cyber incidents can happen from external as well as internal so in this session we will be looking at what who is an Insider what is an Insider threat what are the technical and management controls for the prevention of Insider threats so who is an Insider so Insider is a person who has or had authorized access or knowledge of an organization's resource so when we say what is an organization resource it includes the information of the organization it can include the networks systems other equipments or any facilities of the organization so imagine a person who developed the products and services for an organization he is considered as an Insider a person to whom the organization has supplied computers or laptops or has given network access they are also called insiders a person who has knowledge about the fundamentals of the organization the strengths and weakness of the organization the business strategies and goals of the organization so they are also called Insiders and in the context of government functions also there are insiders so in that context The Insider can be a person who has access to the protected information and in any case if it is compromised that could damage the National Security and Public Safety so now let's look at what is an Insider threat so there are different definitions for Insider threat so we have taken two definition the first one is from cyber security and infrastructure Security Agency it's the National Security Agency of us so according to them an Insider threat is a threat that an Insider will use their authorized access wittingly or un unwittingly to do harm to the Department's Mission resources personal facilities information equipment networks or systems so the second definition is from software engineering Institute at car melan University so their definition of Insider threat is the potential for an individual who has or had authorized access to an organization's critical assets to use their access either maliciously or unintentionally to act in a way that could negatively affect the organization so if you look at this definition there are four key terms individual organization's asset unintentionally or intentionally or maliciously negatively affect the organization so when they say individuals it

can include the current or former employees the full-time or part-time employees it can be temporary employees it can be contractors or any trusted business partners and when they talk about organization asset organization's asset it can include the people of the organization it can include the information the technology and Facilities of the organization so these all things are known as the assets of the organization intentionally or unintentionally for example fraud espionage social engineering so there are they categorize into unintentional or intentional and negatively affect the organization so when they say negatively affect the organization it can create harm to the employees of the organization it can create harm to the customers of the organization it can damage the reputation of the organization it can degrade the confidentiality integrity and availability of the organization it can also disrupt the organization's ability to meet its Mission so for example consider a full-time employee so he has access to information so he accidentally disclosed the information so it it can create a damage to the organization's reputation or it has it can degrade the confidentiality integrity and availability of information so as mentioned it can be unintentional this Insider threat can be unintentional or it can be intentional so there are different types of insiders the first category is malicious insiders so they have a malicious intention they intentionally do the data theft or they intentionally destroy the data so there are there is a second category as the known as The Accidental insiders so these accidental insiders they might be careless they might take the data carelessly so they might unknowingly violate the policy they might not have any malicious intent similarly the other category is negligent insiders so these kind of insiders ignores the policy they don't care about the policy they might not have any malicious intent so all these three kind of insiders be they whether they have a malicious intention or a non-malicious intention they might not have an intention also all these kind of insiders can create problem to the organization so in one of the recent studies they say that from 2019 to 2024 in The Last 5 Years the number of organizations reporting Insider threats or Insider attacks has increased from 66 per to 76 per that means there is an increase in Insider threat detections so as we all know covid-19 pandemic has made remote and hybrid working as a new normal so in that context this remote and hybrid working creates flexibility to the employees but at the same time it creates security concerns to the organization so nowadays research is going on to minimize The Insider threats when the employees are working from home so we'll look at U two case studies about Insider threats so the first case study is about the Edward Snowden incident that most of you might have heard of so this is an example this is a famous example of Insider threat so this Edward Snowden was a contractor for the National Security Agency and he had legitimate access to the databases of NSA so he gathered the you know gathered and leaked the classified documents relating to the secret and controversial government surveillance activities in us and abroad so this incident highlights a significant vulnerability in the security systems that rely on user permissions so they might not had an adequate monitoring of the user Behavior so this example or this case study underscore the need of a robust Insider threat detection mechanism the second incident is about the Tesla Insider threat that happened in 2023 so two former employees of Tesla they have leaked almost 75,000 U personal data of the current and former employees so this is a clear violation of the security policy of Tesla and Tesla has filed lawsuits against these two employees and this incident also illustrates the complex nature of Insider threats so this insiders or the

employees they are trusted people so they are inside the organization so this trusted people or The Trusted employees has the power to exploit their access for malicious purposes or it can be negligence as well so these two incidents highlight the importance of having necessary tools and processes or techniques to ensure that employees can the ex employees also to have the appropriate level of access and when an employee is leaving an organization his access has to be removed so now let's look at some of the technical indicators of Insider threat this is just some examples that we have taken so the first technical indicator is unusual access patterns so this unusual access patterns mean there is an access behavior for every employee so when the employee deviates from the established Norms of an employee or the or its group it is known as unusual access pattern so the examples can include an employee logging in non-working hours for example the working time of employees from say 9 to 5 and if the employee 9: to 5 p.m. so if the employee is trying to log in at 2 a.m. in the early morning so that is a deviation from the established Norms of the employees regular behavior and he is trying to login from an UNF familiar location second one is multiple failed log attempts followed by a successful login so these kind of Insider threat can be an example of compromised insiders where the credentials of the employee might have been compromised second one is Access Control violation so in that case the employees try to access another access restricted resources or systems which they might not have authorized access so the indicator again is the repeated failed login attempts or access to restricted areas and some employees try to escalate their privilege or change their role without proper authentic authorization the third technical indicator is data exfiltration it refers to the unauthorized transfer of data outside the organization for example some employees U download a large volume of data or U upload large volume of data that is not typical to their particular role and they might use USB drive or pen drive to transfer the data to the technical the sensitive data to their personal devices so these are examples of technical indicators of Insider threats and now let's look at the motivation of Insider threats why employees are involving in Insider threats or why they are acting against their own organization one of the top motive is financial gain so they exploit their access to sensitive data for personal financial benefit they might sell the confidential information on the dark web or even to the competitors and some employees for example they are in the sales team or they might engage in fraudulent activities they manipulate the financial data so in order to get bonuses or they might inflate the expense report so basically financial gain is one of the top motivator of Insider threats next is the dis so some of the employees might be dissatisfied with the work conditions they might have a problem with their colleagues they might have a problem with their supervisor or they might not like the policies of the management so there are contexts where or there are situations where that can lead them to act in a way which is against the organization maybe a Malay is inside a threat an example would be employees May leak sensitive information as a form of revenge against their pursued mistreatment they might not have received the salary hike as they expected or they might not have got a promotion that they have expected so in that Cas in that case they might have some dis dissatisfaction with the work condition that may lead them to malicious Insider threat they can also so you know destroy the data or destroy the projects to demonstrate their frustration and another motivation can be ideology so there can be ideological belief that may make them act against the organization they may believe that

the actions of their company or the higher officials are unethical or contrary to their belief an example would be they may leak the information to expose unethical practices that is happening in the organization they may believe that they are doing it in the interest of the public another example is individuals may leak sensitive data to activist or organization that align with their beliefs believing that they their contribution they're contributing to a greater cause for example social justice and this figure shows the top motives of Insider actors misusing privileges so this is taken from the data breach investigation report by verizone in 2023 so as we mentioned when the employees violate the information security policy of the organization that leads to Insider threat so there are some popular theories in information security which explains why employees violate the policies so the theories are taken from different fields for example criminology psychology Etc so we will look at three theories that is that that are popular and they they are used to explain this security policy violation so the first one is routine activity theory that was developed in 1970 so the key elements of this Theory include a motivated offender a suitable Target and lack of capable guardianship so this Theory say is that the probability that a crime that will occur at a specific time and place may be taken as a function of the convergence of motivated offender suitable Target and absence of capable guardianship against the crime that means if there is a motivated offender and there is a suitable Target and there is a lack of capable guardianship then the possibility of crime can occur so this theory is taken from criminology and this is taken to information security policy domain as well the second theory is neutralization theory that was developed in 1957 so according to this Theory there are different neutralization techniques so these techniques will provide way to the employees hello so this technique will provide a way to the employees to rationalize their behavior to justify their behavior that violate these Norms so in the original Theory by sykes and matza there were five techniques of neutralization denial of responsibility denial of injury denial of victim Etc and there are some other subdomains that was added later by different Scholars R me 9 I it r 9 I sorry so the third theory is deterrence Theory so the core principle of this theory is that employees or people commit crime when they perceive the benefit to outweigh the potential consequences so they will engage in a rule breaking Behavior U they will consider the severity of the punishment side of the punishment and certainty of the punishment so they outweigh they will think okay they'll take a rational decision if the benefit is more then they'll involve in the crime so these are the three theories used to popular theories used to explain security policy violations now let's look at the Technologies for Insider threat detection and prevention so you might be you might have heard of some of these Technologies the first one is seam so security information and event management so the organization uses this particular tool so that it Aggregates and analyz the security data from different sources across the organization and you will get all those data in real time so this particular tool will correlate the log from various sources such as U firewall or servers and it will detect anomalies so if there is an anomaly it will generate an alert and it can be based on the predefined rules and it uses machine learning as well and an alert will be sent to the particular team and the team will be looking at it similarly data leak prevention so you know after this pandemic people are working from home and most of the companies have given laptops to their employees so there is T there a tendency that these employees can take the data to their personal USB drive so there are softwares called software which prevents

this data loss so they monitor and protect the sensitive data across endp points and networks so if somebody is trying to transfer the data to their personal devices so it detects and blocks this unauthorized data transfers even if you're trying to send an email with an attachment that is classified as sensitive these DLP softwares will detect and block and it will be sending an alert to the administrators the third one is uba or UEA that is user Behavior analytics or user and entity Behavior analytics so these tools will monitor the activity of the user and it will create a baseline behavior of the user behavior and if there is any abnormal behavior or any deviation from the normal behavior it will indicate an Insider threat will send an alert to the you know the administrator so this this tool also uses machine learning algorithms to adapt to the changes in user Behavior over time so having said this there are always false positives and false negatives for these kind of tools so now let's look at the management controls for Insider threat mitigation so National Insider threat task force nitf so it's an agency in us so they have established some guidelines for having Insider threat programs so they say every organization every MNC should have an Insider threat program so their guidelines include designate a senior official the senior official should be responsible for the overall management of this Insider threat program so he should ensure that policies and procedures are complied and it is promoted in the organization and an Insider threat working group has to be formed which has to be multidisciplinary so the they are the governance group so it it can the the members of this particular working group should be from different domains people from HR should be there people from sales should be there so every domain the multidisciplinary nature so the governance group will be from different domains and this particular group the threat The Insider threat working group will be responsible for reviewing the existing policies of the organization they should review the existing policies the procedures and standards of the organization and the program third is they have to establish governance and publish The Insider threat policy so this principles the this U you know Insider threat policy and the principles will be a function of The Insider threat program in the organization so how the company align its Insider threat program to its U business and its culture so this working group also develop the policies and procedures in such a way that it is grounded in the legal authorities and they also have to implement a formal training and awareness program so all the employees all the Personnel of the organization should be given training on how to comat Insider threats like what are the reporting procedure what are the you know key indicators of Insider threat so everything has to be covered in the training and it should not be a onetime training this awareness and mitigation training should be continuous it should go on so most of the companies when the employees join they will give a maybe on the first week they will give a training on security and after that there might not be anything about security training so this nitf guidelines say that this training should be a continuous process and every employee should be included in that be it be a lower level employee it be a higher employee so everyone should be included in this training and the final one is create an inside threat program office so there should be a formal maintenance process for reviewing and revising the policies procedures and standards so The Insider threat program office will be responsible for that so these are the five guidelines for establishing an Insider threat program so coming to the conclusion what can we learn from these Insider threat cases so the some of the incidents that we have seen so this highlight the increasing role that insiders when we talk

about insiders it can be the current or former employees so they use their legitimate access they use their legitimate privilege to expose their company system or leak the data accidentally so it can be for Revenge it can be for money so we have seen different motives so the security teams should focus on internal threats as well they should not just focus on external hackers they should focus on internal or the Insiders as well and along with the technical control it is important to understand the behavioral factors that motivate the employees to non-comply with the security policies the organization should understand why employees are violating the policies or why are they not complying with the policies because the behavior of the Insider is recognized as a significant source of data breach and this highlights the need of Technical and behavior analysis so a combination of Technical and behavioral approaches are needed for identifying and you know mitigating The Insider threat problem so according to gkull CEO even Progressive companies that can afford the best cyber security protection can be taken down by one malicious Insider so even if your company has the best security policy if an Insider tries to or Insider wants to let your company down he has the power to do that if he has the right skills and building a security culture cultivating information security awareness and effectively monitoring the security Behavior are important ways to reduce Insider risk and U that's it thank you any doubts no sir no doubts it's a great session and very informative for us thank you thank you sir so much for your sessions so sir any other session in there or this is complete today for yeah this is the final interactive session okay sir okay thank you sir is Professor S there yeah Professor Saji yeah are there any questions from the audience hello so after cyber security and privacy course what we can do another course in from the mptl can you suggest me hello yeah afternoon sir good afternoon what's your question sir after cyber security course what we can do another course from the mpts side well this is based on your interest as I said this this course gives a foundation on cyber security and privacy from A administrative techno administrative perspective so if you want to build on technical competency then you have to look for courses from CS computer science side what additional courses they offer say in Quantum Computing or differential privacy there are responsible ai ai systems responsible AI so there are different new technologies and challenges emerging out of those Technologies so you can browse NP and S and choose the courses based on the outlines correct hello sir good afternoon sir very good afternoon sir I wanted to ask a kind of a humble question so basically when I am preparing for the exam the course is lot of theoretical stuff which is hard to remember and when we actually work in domain it's a cakewalk to remember them like we understood the concept what is the difference between different plans and why they have been named so like when we actually in domain and see those plans we we get we get that feeling and a muscle memory that okay what this means and why those are there but reading from that book and that book also does not contain examples and all it becomes very difficult to memorize them for the exam perspective so I just wanted to ask in exam we would expect more this kind of question or it would be more on the Concept side not on the fact side or the definition side well this is difficult to say what will come in the exam but you you have seen the assignment questions so which are both facts as well as checking your learning so be thorough with the textbook and also the slides that are shared with you and other references given and examination is is going to test your ability to integrate this different aspects and able to answer relevant questions so

so that examination is Set with a particular purpose to check your learning I can't tell you what questions will come but of course these are actually reading you have to go through some of the things maybe may not be interesting to you but you have to read again and understood get this I that's why I said like it's kind of a humble because like I have around 10 years of experience and when I was in degree some of the concepts I read and hard to correlate and memorize them but when I'm actually into job I know it's very easy to you know when you work with them you just realize why they are here and what what's their practical relevance is but again this exam s since I'm preparing for it domain so again I'm finding the same phase where I could not practically correlate I have to remember it for the exam yeah yeah Academy is not just practice but it's also Theory Theory would be useful for practice but you have to understand Concepts clearly for that you have to read there is no alternative okay but we are not going to ask you what is the date of birth of a person or that's not the kind of things we interested yes okay sir thank you okay all the best hio hi sir can you suest I didn't get the point are you asking for some book yeah yeah I'm I'm just asking about the some textbook which will be related for information security GRC what is the topic security GC books it's already given in the reference right a textbook is already given to you okay haven't you seen the course outline the textbook the same books which you are already which is mention in npdl right right right that is the best textbook I know which which gives both Technical and managerial aspects and hence I want suggest any other book for this course at the moment hold on for how many questions that any other questions sir so someone is asking how many questions will come in examination and the time duration and is there any negative marking sir you are on mute in case if you're answer yeah the administrative team will be giving a clear instruction on that that about the duration and negative markings so we will publish it in the Forum okay sir hello hello yes yes yes yes kalp hi yes good afternoon sir this is kalp sh actually sir there are lots of presentations over there on the based on case studies sir hello hello can are you hearing yes yes yes I can hear yes sir there are lots of based on case studies so is there any requirement that we have to go through all the case studies for the preparation of examination I think in the last session Professor has mentioned that we won't be asking directly from the cases because some of the cases might not be available publicly yes sir I hope that answered your question okay thank you any other questions yes hi have already asked who said that I need a sest book for cyber in information security GC mhm so is the is is there any answer from from his side I'll check with him and I'll update it okay I'm just just waiting I think sir has already U responded to that question right yeah but but same sometimes he's said that I will sest another book also for that no no can you actually say that again what's your problem hello I just asked about the some textbook which is related with information security GRC BR GRC yeah for GRC alone yes I'm not you see I can't quickly tell you any reference for GRC alone because that is just one small Topic in the course one session part of a session we spend on GRC but you see nowadays you can search these books have rankings for example when I choose this textbook with men for this course we did review all of the textbooks available and fortunately there was a research paper a researcher actually published a paper on teaching cyber security for graduate students and had done a review of various textbooks and this textbook ranked the highest okay so you may have to look for such information you know so everything is not easily available you know as you ask so if you ask

for a specific textbook in a particular field it's always good to do some research are there some reviews on textbooks on grc's available in public domain and go through it and decide okay I'm not aware actually okay sir but as far as the course is concerned we have given you the best textbook okay okay I got your hello good afternoon actually I missed two assignments so does it affect on my final score well that's a technical question which you have you can actually direct to the the NP technical team okay they will tell you because there are clear rules you must have read that in the beginning what is assignment score required so first try understand that and if you get this answer from the announcement of the course itself then then it is fine otherwise you may have to write to NP okay okay sir thank you goodon sir good afternoon sir so far we learned the policies standards guidelines and procedures MH so how do we like the cyber security Theory into practical application sir well this is a big question as to how you do practical application it depends on what practical problem you have and what is the context of that problem whether it's what kind of organization is at what level it is is individual is it group or organizational so the point is application depends on the context so there are so many different context of security a course Academy we actually give Concepts and Frameworks which you can select or reflect on when a practical problem comes so without a context cannot say what is okay sir like incident respond and like the incident response so what do you suggest for it yeah so that's a question have to answer in the final exam for example what is incident response and what setting is it relevant what is an incidence and what kind of management planning is incidence planning inol so that is actually covered in the class yes sir I'm actually yes sir how to get it into practicality like to practice or something like that in real time go to organization depends on context right sir one thing may be helpful for him like Cisco Packet Tracer is a free software so so that you can download create architectures config firewall servers kind of a practical implementation why no no that is talking what you're talking about is a tool okay a tool a number of tools are available not just Cisco but how you apply is the question okay how you apply requires the context that's what I'm saying so if you want to travel from say A to B if that is all that is given you have so many ways of traveling from A to B you can walk you can cycle you can take a motorbike you can take a car you can fly you can take ship you know without giving the context where is a where is B you can't actually give any advice okay so this kind of questions as to how we practically apply is U not a good question because we don't know the context actually sir I what I did and what you answered this kind of answers are not expected because tools is not application tools is actually a support or an aid to implement something a problem requires thorough understanding and also maybe the nas N St U resources that is introduced in the course is useful for example incident response they keep templates okay those templates help you understand what are the information that is required to do an incident response planning okay so look at that instead of going for some software or tool first okay so those those guidelines are already given in the course and depending on your problem context for example whether you're small organization large organization nature of business how critical is it etc etc and what similar firms are doing so there are various aspects you can consider when you think of applications and is the organization willing to invest in say cyber security because in order to do incident response planning for example you need to have a team and you need to have a commitment to do this all this involves cost as well people's time okay so so these are practical

considerations when you go to organizations okay the course cannot answer you what I should do that is not possible unless the context is n hello hello yes sir we can hear you yes yes yeah yeah so you know this has given you like you know you you're given a map and now for you to travel you have to use the maps so the purpose of the course was to give you sort of you know broad guidelines or Maps or you know ideas about this field of cyber security okay now get into the field and start using the map and try understand the context Etc hello are there more questions the one who asked the question the name are you unhappy or are you getting some point yes sir actually I think I found the answer we face this problem in classrooms also because students especially from working professionals they want their company's problems to be solved in the classroom we never do that because we did not know the compan right should never give wrong advice or took advice Etc it's not meaningful yes sir I understand thank you hello sir good op yes earlier what we have been the discussion Sy that PP and not sorry what is the complaint is that a complaint the discussion problem solving questions are there now ah right that is not updated in the not updated what what is not updated this one this Lo the PowerPoint H yes sir PowerPoint or okay oh okay okay okay I think they are listening to this and this is again technical side we know we so so they must be taking care of it okay exam you can write this in the chat Forum also they actually read every issue that comes and they will address it before that we have to glance once again ah okay got it but this will be this will be done this will be done yeah yeah thanks forting yeah yeah yeah okay I think there are no more questions so there are few questions in the chat I think we can answer it in the Forum so we'll respond to those questions okay okay fine fine okay okay then if there are no more questions and we done we can close it here thank you very much for joining and all the best to all the participants for examination do well and read early go through the lectures once again and and reflect on what you learned and hopefully you will take your learning forward for more courses or for applying this in your own working environments all the best thank you thank you so much sir thank you sir for e e e e e